Sistema de clasificación del nivel de riesgo de los activos de información mediante Machine Learning

Carrera de Ingeniería de Sistemas Informáticos — Universidad Boliviana de Informática (UBI)

Estado: prototipo académico basado en datos sintéticos.

Advertencia: este proyecto no evalúa activos reales de la UBI ni demuestra cumplimiento de ISO/IEC 27001:2023. Los resultados corresponden exclusivamente a datos sintéticos.

1. Problema y objetivo

Los activos de información pueden presentar distintos niveles de impacto y exposición. Este proyecto implementa un prototipo que clasifica activos en niveles Bajo, Medio y Alto a partir de características simuladas relacionadas con confidencialidad, integridad, disponibilidad, exposición a amenazas, vulnerabilidades, controles y respaldos.

Objetivo: desarrollar y evaluar un clasificador Random Forest para asignar una categoría de riesgo experimental a registros sintéticos de activos de información.

2. Alcance

El sistema demuestra el flujo de generación de datos, entrenamiento, evaluación, API y frontend. No evalúa activos reales de la UBI ni determina cumplimiento normativo. La adaptación a uso institucional requeriría inventario autorizado, criterios de riesgo aprobados, revisión experta y validación externa.

3. Dataset y preparación

Se generaron 1.200 registros sintéticos con semilla **20261021**. Las variables incluyen tipo de activo, confidencialidad, integridad, disponibilidad, exposición a amenazas, cantidad de vulnerabilidades, madurez de controles, exposición a Internet, presencia de datos personales y calidad de respaldos.

Las etiquetas se derivan de una puntuación artificial que combina exposición, impacto, controles, respaldos y ruido aleatorio. Los puntos de corte se calculan mediante cuantiles de la puntuación generada. Esta es una regla didáctica, no una fórmula oficial de ISO/IEC 27001 ni una evaluación institucional.

4. Modelo y línea base

La línea base es DummyClassifier con estrategia most_frequent, que siempre predice la categoría más común del conjunto de entrenamiento. El modelo propuesto es RandomForestClassifier con 250 árboles, class_weight='balanced', min_samples_leaf=2 y semilla fija. La variable categórica asset_type se transforma mediante One-Hot Encoding; las variables numéricas se imputan con la mediana.

5. Métricas y validación

Se utiliza **F1 macro** como métrica principal, pues asigna el mismo peso a cada clase. También se reportan exactitud, F1 ponderado, reporte por clase y matriz de confusión. La partición estratificada es 70 % entrenamiento (840 registros), 15 % validación (180 registros) y 15 % prueba (180 registros). El conjunto de prueba se reserva para la evaluación final.

Resultados en prueba sintética:
Línea base: exactitud 0.356; F1 macro 0.175; F1 ponderado 0.187.
Random Forest: exactitud 0.722; F1 macro 0.726; F1 ponderado 0.722.

El F1 macro de Random Forest fue 0.726, frente a 0.175 de la línea base. Esta diferencia solo refleja el comportamiento en datos sintéticos generados por reglas conocidas; no debe generalizarse al contexto real de la UBI.

6. Arquitectura e interfaz

El backend se implementa con FastAPI. El endpoint POST /api/predict valida los campos, construye un registro tabular, carga el modelo persistido y devuelve la clase estimada junto con puntuaciones por clase. El frontend HTML/CSS/JavaScript permite introducir las variables y mostrar la respuesta del backend.

7. Pruebas

Caso válido: introducir valores dentro de los rangos y comprobar que se devuelve una clase.
Caso difícil: probar valores extremos admitidos, por ejemplo alta exposición, varias vulnerabilidades y controles débiles.
Entrada inválida: intentar enviar un valor fuera de rango (por ejemplo, confidencialidad 8) y verificar el error de validación HTTP.
Flujo completo: enviar datos desde el formulario al endpoint y mostrar la respuesta real del modelo.

Las pruebas automatizadas del dataset verifican las columnas, etiquetas y rangos. Antes de la entrega final deben ejecutarse también las pruebas manuales de integración y añadirse capturas reales.

8. Limitaciones

Las categorías son generadas por reglas sintéticas; por tanto, el modelo aprende una aproximación de esas reglas. El F1 obtenido no demuestra que el modelo clasifique correctamente riesgos reales. Las puntuaciones por clase no deben interpretarse como probabilidades reales de incidentes. No se ha evaluado el cumplimiento de ISO/IEC 27001:2023. Se requiere validación con datos autorizados y criterios aprobados antes de un uso institucional.

9. Conclusiones

El prototipo permite demostrar una cadena reproducible de generación de datos, entrenamiento, comparación con una línea base, evaluación y despliegue web de un clasificador. La principal conclusión metodológica es que la calidad y representatividad de los datos y de las etiquetas condiciona la validez del modelo.

10. Referencias

Breiman, L. (2001). Random forests. *Machine Learning, 45*, 5–32.
scikit-learn developers. (s. f.). *scikit-learn documentation: RandomForestClassifier, DummyClassifier and model evaluation*.
International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Verificar con la biblioteca institucional la edición y adopción normativa aplicable al alcance del proyecto.

Anexo: estructura y ejecución

Consultar README.md para instrucciones de instalación, generación del dataset, entrenamiento, ejecución del backend y apertura del frontend.